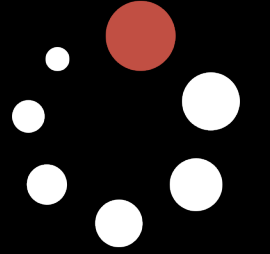


cyber|seven:

S T R A T E G I E S



Assess | Plan | Respond



STORM CyberCare

Strategic, Tactical & Operational Risk Management

Assess | Plan | Respond

Full Service offering for Reinsurers, Insurers,
Brokers and Clients.

Assess

Lightweight cyber risk assessments to enable clients to learn and improve their cyber security and to enable insurers and reinsurers to manage book risk. **New self-assessment to be launched soon.

Respond

Delivering a fully coordinated and Integrated Cyber Incident Response Team (I-CIRT)

cyber|seven:

Plan

Helping insured clients to create, learn (through training) and exercise/test their plans in dealing with different types of cyber incidents in the context of their business. Infosheet attached.

Assess | Plan | Respond

What Boards Don't Understand About Cybersecurity

The costly and dynamic nature of cybersecurity threats makes them a top risk for many businesses; board directors and management, however, often struggle with understanding and responding to the scope of this rapidly changing risk...

STORM **Cyber.Care** Assess | Plan | Respond

Full Service offering for Reinsurers, Insurers, Brokers and Clients.

...For most boards, cybersecurity is far from a core competency. Many C-suite executives and board directors, are not well-versed in security measures and would be unable to effectively guard against and mitigate an attack

Michael Chertoff

Former Secretary of the U.S. Department of Homeland Security

April 2018

What Boards Don't Understand About Cybersecurity



with unclear scope of this rapidly changing risk...

Need to factor in the capabilities delivered 3rd parties.

The Way Businesses Operate

“...For most boards, cybersecurity is far from a core competency. Many C-suite executives and board directors, are not well-versed in security measures and would be unable to effectively guard against and mitigate an attack”

“Tactics without strategy is the noise before defeat.”

Michael Chertoff
Former Secretary of the U.S. Department of Homeland Security

April 2018

Spot the Problem!

The Way Businesses Operate

This is a strategic audience

These are all operational actions.

Need to factor in the impact of the threat delivered 3rd

Management Specialists & Staff

Technology is a threat.

“

National Cyber Security Centre

BETA This is our new site, your feedback can help us to improve it.

About NCSC Information for... Advice & guidance Education & skills Products & services

GUIDANCE

Board toolkit: five questions for your board's agenda

A range of questions that the NCSC believe will help generate constructive cyber security discussions between board members and their CISOs.

PUBLISHED
11 September 2018

REVIEWED
11 September 2018

WRITTEN FOR ⓘ
Small & medium sized organisations
Public sector
Large organisations
Cyber security professionals

Contents

Q1: How do we defend our organisation against phishing attacks?

Q2: How does our organisation control the use of privileged IT accounts?

Q3: How do we ensure that our software and devices are up to date?

Q4: How do we make sure our partners and suppliers protect the information we share with them?

Q5: What authentication methods are used to control access to systems and data?

Spot the Problem!

Adapting Cyber Narrative to Strategic 'Board' Thinking

What are the STRATEGIES we need in-place so that Tactics and Operations can deliver effective management of cyber risks?



BETA This is our new site, your feedback can help us to improve it.

About NCSC Information for... Advice & guidance Education for... About us in... Keep up to date

GUIDANCE

Board toolkit: five questions for your board's agenda

A range of questions that the NCSC believe will help generate constructive cyber security discussions between board members and their CSOs

PUBLISHED
11 September 2018

REVIEWED
11 September 2018

WRITTEN FOR ⓘ
Small & medium sized organisations
Public sector
Large organisations
Cyber security professionals



This is a strategic audience

These are all operational actions.

- Governance Fundamentals
- Capability
- Responsibility
- People Skills Technology
- Direct Board Control i.e. Measure & Manage
- Board Level Language & Understanding

Get the STRATEGY right and have high confidence that risks will be managed effectively at TACTICAL & OPERATIONAL levels.

Contents

Q1. How do we defend our organisation against phishing attacks?

Q2. How does our organisation control the use of privileged IT accounts?

Q3. How do we ensure that our software and devices are up to date?

Q4. How do we make sure our partners and suppliers protect the information we share with them?

Q5. What authentication methods are used to control access to systems and data?

© Crown Copyright 2018

Adapting Cyber Narrative to Strategic 'Board' Thinking

What are the **STRATEGIES** we need in-place so that Tactics and Operations can deliver effective management of cyber risks?

- 
- The logo for 'cyber|seven' features the word 'cyber' in a lowercase sans-serif font, followed by a vertical bar, and then 'seven' in a larger, bold, lowercase sans-serif font. To the right of 'seven' is a graphic of seven dots arranged in a circular pattern, with one dot colored red and the others black. Below the word 'seven', the word 'STRATEGIES' is written in a smaller, spaced-out, uppercase sans-serif font.
- Governance Funding
 - Capability
 - Responsibility
 - People Skills Technology
 - Direct Board Control i.e. Measure & Manage
 - Board Level Language & Understanding

A Board-Level Rapid Risk Review

Get the **STRATEGY** right and have high confidence that risks will be managed effectively at **TACTICAL & OPERATIONAL** levels.

STORM Approach

1..... Analysis of the data from the first-hand management of a range and number of common types of cyber incident (breaches, fraud, ransomware etc.)

2..... Identify key common **STRATEGIC** failings: there happened to be seven!

3..... Assess these strategies using a simple, easy-to-use online adaptive tool: Entirely

- “Business-Language” Q&A: completed in just 26-clicks
 - Unlikely need for technical delegation
- Free and anonymous at point-of-use: Low-cost registration £45 for;
 - Certification; if Cyber Strategist or,
 - Remediation checklist and guidance to achieve Certification

4..... Offer Cyber Strategists discounts on insurance, security products & services.

Determining the Key Strategies underpinning C/7

STORM Approach

1.....

Analysis of the data from the first-hand management of a range and number of

col
fra

3.....

As

	A	B	C	D	E	F	G	H	I	J	K	L	M	N
	Date	Op Name	Incident Type	Lead	Client Lead	Client Sector	Insurer	Responsibility for Cyber Risk	Asset Awareness	Approx IT Budget	Payment Control	IT Staff Count Ratio	Skills & Awareness	Notes
2	25/09/2018	Op Alban	Mailbox Hijack	HB	I Dinning	IT Services	CNA Hardy	N	N	11.00%	N	2.00%	N	
3	26/02/2016	Op Anchor	Phishing-Fraud	NHB	Monica S	Financial	N/A	N	N	3.00%	N	1.00%	N	
4	20/09/2018	Op Avon	APT Malware	NHB	R Mead	Construction	QBE	N	N	3.00%	N	2.00%	N	
5	15/09/2017	Op Bradford	Hack-Ransomware	HB	Mandy V	Logistics	CNA Hardy	N	N	2.00%	?	3.00%	N	
6	21/07/2017	Op Brighton	Mailbox Hijack	NHB	Simon M	Legal	QBE	N	N	1.00%	N	2.00%	N	
7	16/05/2017	Op Budapest	Email-Ransomware	NHB	Stuart M	Logistics	Markel	N	N	3.00%	?	1.00%	N	
8	13/12/2016	Op Copenhagen	SE-Fraud	NHB	Tanya B	Legal	Axis	N	N	2.00%	N	3.00%	N	
9	05/05/2017	Op Cork	Hack-Ransomware	NHB	Ashish A	Construction	QBE	Y	N	4.00%	?	4.00%	N	
10	21/09/2017	Op Croydon	Mailbox Hijack	NHB	Nabiha A	Engineering	QBE	Y	N	3.00%	Y	2.00%	N	
11	11/04/2018	Op Debden	Mailbox Hijack	MS	Lucy W	Charity/NGO	CNA Hardy	N	Y	1.50%	N	4.00%	N	
12	11/09/2018	Op Degania	DDoS	HB	Eran E	Gambling	CNA Hardy	N	N	4.00%	?	3.00%	N	
13	30/09/2017	Op Doncaster	Unauthorised Access	NHB	Kate M	Wildlife Park	QBE	N	N	2.50%	?	8.00%	N	
14	04/05/2016	Op Dusseldorf	Hack-Ransomware	NHB	Alex L	IT Services	CNA Hardy	N	Y	12.00%	N	22.00%	N	
15	01/12/2017	Op Ely	Mailbox Hijack	MS	Steve R	Legal	CNA Hardy	N	N	2.00%	N	1.00%	N	
16	03/01/2017	Op Falmouth	Hack-Ransomware	ED	Chris J	Insurance	Markel	N	N	3.00%	N	2.00%	N	
17	27/01/2017	Op Faversham	Mailbox Hijack	NHB	E Finch	Insurance	QBE	N	Y	3.00%	N	2.00%	N	
18	18/11/2016	Op Glasgow	Botnet Hijack	ED	Martin H	Legal	QBE	N	?	2.00%	?	4.00%	N	
19	18/09/2018	Op Harrogate	Mailbox Hijack	MS	Andrew M	Legal	Axis	N	N	2.00%	N	1.00%	N	
20	12/02/2017	Op Hastings	Hack-Ransomware	MS	Mario S	Legal	CNA Hardy	N	Y	2.00%	Y	3.00%	N	
21	16/06/2017	Op Hatton	Mailbox Hijack	MS	Andy B	Private Client	CNA Hardy	N	N	4.00%	N	2.00%	Y	Current & Previous
22	22/09/2017	Op Haywood	Hack-Ransomware	HB	Vanessa D	Design	QBE	N	N	1.00%	N	0.50%	N	Older than Previous
23	10/11/2017	Op Highley	Website hack	ED	Phil B	Financial	N/A	N	Y	5.00%	?	3.00%	N	Older than Previous
24	20/06/2018	Op Hornsey	Website hack	NHB	Cynthia P	Recruitment	QBE	N	N	1.00%	?	0.50%	N	Older than Previous
25	13/04/2018	Op Lafayette	SE-Fraud	NG	Shashi R	Reinsurance	N/A	N	Y	2.00%	N	0.50%	N	Older than Previous
26	16/01/2017	Op Leicester	Mailbox Hijack	NHB	Neil A	Legal	AmTrust	N	N	0.50%	N	2.00%	Y	Current & Previous
27	01/11/2017	Op Leith	Mailbox Hijack	MS	Jamie M	Education	CNA Hardy	N	N	1.00%	N	1.00%	N	Current & Previous
28	11/04/2018	Op Lowestoft	Hack-Ransomware	HB	Mark B	Legal	QBE	N	N	0.50%	N	1.00%	N	Older than Previous

Determined during IR. Unique first-hand insight. Items distilled to C/7.

lings:

counts on
cts & services.

Cyber Risk Indicators: Cyber|Seven Strategies



Responsibility



Asset
Awareness



IT Budget



Payment
Control



IT Staff Count
Ratio



Skills &
Awareness



Technology
Versions

Need to factor in the capabilities delivered by vendors.

Informed by cyber incident experience

Cyber|Seven: Self-Assessment

Cyber Risk Indicators: Cyber|Seven Strategies

cyberseven.global

cyberseven

STRATEGIES

Sign Up

Login

Progress

Question 1: Responsibility for Cyber Risk

Board serving champion

Regular reporting on cyber issues

Risk register include cyber risk entries

Question 2: Asset Awareness

Asset register records data assets

Assets are categorised in terms of criticality

Information systems drive cyber risk assessments

Systems drive your cyber security plan

Question 3: IT Budget

IT budget as a percent of revenue

Separate budgets for IT and cyber security

Question 4: Payment Control

Segregation of duties when making payments

Requests to change payee details

Do you assure automated payments

Question 5: IT Staff Count Ratio

Ratio of IT staff to end users

Save progress

Are you a Cyber Strategist?

Answer all seven questions below to find out.

Achieve glory in the management of cyber risk. Whilst this is just the foundation for business resilience it provides assurance to insurers and makes your organisation eligible for a discount on the first year premium of your cyber insurance. Click here to see which insurers are offering a discount.

Question 1

Responsibility for Cyber Risk

Do you have a board serving champion for Cyber Risk?

Yes

No

Owns overall cyber budget only

Owns cyber budget and IT budget

Doesn't own the cyber budget

Do the board receive regular reporting on cyber issues & initiatives?

Yes

No

From the Board serving champion

From another who is a cyber specialist in the organisation

From someone else in the organisation

Does the organisations risk register include cyber risk entries?

Yes

No

Maintained by the Board serving champion

Maintained by a staff member who is a cyber or risk specialist

Maintained by someone else in the organisation

Need to factor

dent experience

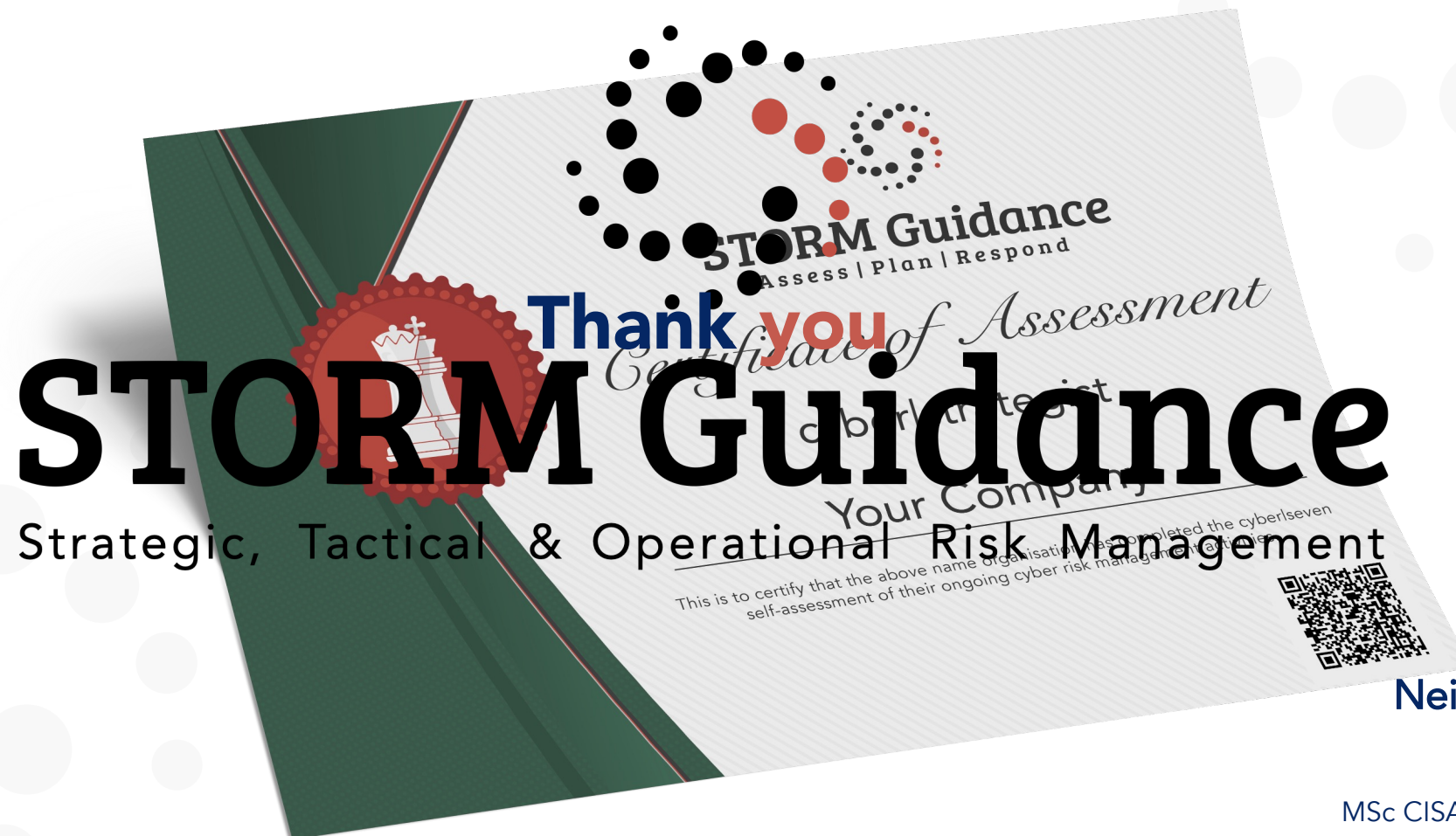
Cyber|Seven: Self-Assessment

Cyber|Seven: Self-Assessment

cyberseven.global

The image is a composite of a digital user interface and a physical certificate. On the left, a digital screen shows a 'Progress' section with five questions and their answers. The questions are: 1. Responsibility for Cyber Risk, 2. Asset Awareness, 3. IT Budget, 4. Payment Control, and 5. IT Staff Count Ratio. The answers are: Board serving champion, Regular reporting on cyber issues, Risk register include cyber risk entries, Asset register records data assets, Assets are categorised in terms of criticality, Information systems drive cyber risk assessments, Systems drive your cyber security plan, IT budget as a percent of revenue, Separate budgets for IT and cyber security, Segregation of duties when making payments, Requests to change payee details, Do you assure automated payments, Ratio of IT staff to end users, and Maintained by the Board serving champion. On the right, a physical certificate titled 'STORM Guidance Certificate of Assessment' is displayed. The certificate is awarded to 'cyber|strategist' for completing the 'cyber|seven' self-assessment. A QR code is visible on the certificate. The certificate also features the 'STORM Guidance' logo and the text 'Assess | Plan | Respond'.

Cyber|Seven: Self-Assessment



Neil Hare-Brown
CEO

MSc CISA CISSP CITP MBCS